

Tema 6.

Normativa de seguridad (Políticas, Normas y procedimientos)

Contenidos

INDICE

- UNE ISO/IEC 27001
- ESQUEMA NACIONAL DE SEGURIDAD
- ISA/IEC 62443
- RGPD

ESTÁNDARES DE SEGURIDAD DE LA INFORMACIÓN

NERC

NORTH AMERICAN ELECTRIC
RELIABILITY CORPORATION



NIST National Institute of
Standards and Technology
U.S. Department of Commerce



ISO/IEC 27001



<http://www.iso27000.es/>

1. NOMENCLATURA

- ❑ **ISO/IEC 27001** es un estándar para la seguridad de la información (*Information technology - Security techniques - Information security management systems - Requirements*) aprobado y publicado como estándar internacional en octubre de 2005 por International Organization for Standardization y por la comisión International Electrotechnical Commission.¹

- ❑ ISO/IEC 27001:2005
- ❑ ISO/IEC 27001:2013
- ❑ ISO/IEC 27001:2022

- ❑ **UNE-EN ISO/IEC 27001:2023** es la versión oficial en español de la norma europea EN ISO/IEC 27001:2022

- ❑ Los documentos normativos **UNE (acrónimo de Una Norma Española)** son un conjunto de normas, normas experimentales e informes (estándares) creados en los Comités Técnicos de Normalización (CTN) de la Asociación Española de Normalización (UNE, antes llamada AENOR).

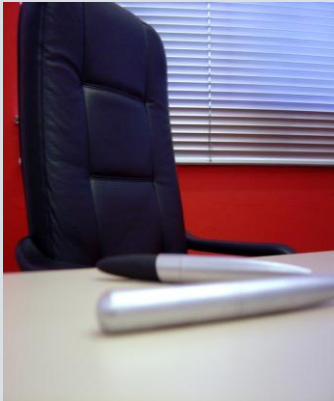
2. GENERALIDADES

- La **ISO 27001** es una norma internacional que permite el **aseguramiento**, la **confidencialidad** e **integridad** de los datos y de la información, así como de los sistemas que la procesan.
- El estándar **ISO 27001:2022** para los **Sistemas Gestión de la Seguridad de la Información** permite a las organizaciones la **evaluación** del riesgo y la aplicación de los controles necesarios para **mitigarlos o eliminarlos**.
- La aplicación de **ISO-27001** significa una **diferenciación** respecto al resto, que **mejora** la competitividad y la imagen de una organización.
- La **norma ISO 27001** proporciona las herramientas para poder implementar un Sistema de Gestión de Seguridad de la Información en una organización.



2. GENERALIDADES

- ☐ La seguridad en una organización es responsabilidad de cada uno de los empleados.
- ☐ Dirección debe establecer las directrices a seguir por toda la organización.
- ☐ Es necesario establecer una estructura de gestión de la seguridad de la información.



3. SISTEMA DE GESTIÓN DE LA SEGURIDAD DE LA INFORMACIÓN (SGSI)

- ❑ Un **SGSI** es para una organización el diseño, implantación, mantenimiento de un **conjunto de procesos para gestionar los activos** minimizando los riesgos de seguridad
- ❑ El SGSI es un sistema cuyos fines son la planificación, ejecución, verificación y mejora continua de un conjunto de medidas que permiten **reducir el riesgo** de seguridad
- ❑ Un buen **punto de inicio** para la implementación de la seguridad de la información puede basarse en requerimientos normativos esenciales o en **controles** considerados como práctica común para la seguridad de la información.
- ❑ Por lo general las organizaciones con un nivel de madurez medio en seguridad disponen de **un conjunto controles, pero no de un SGSI**

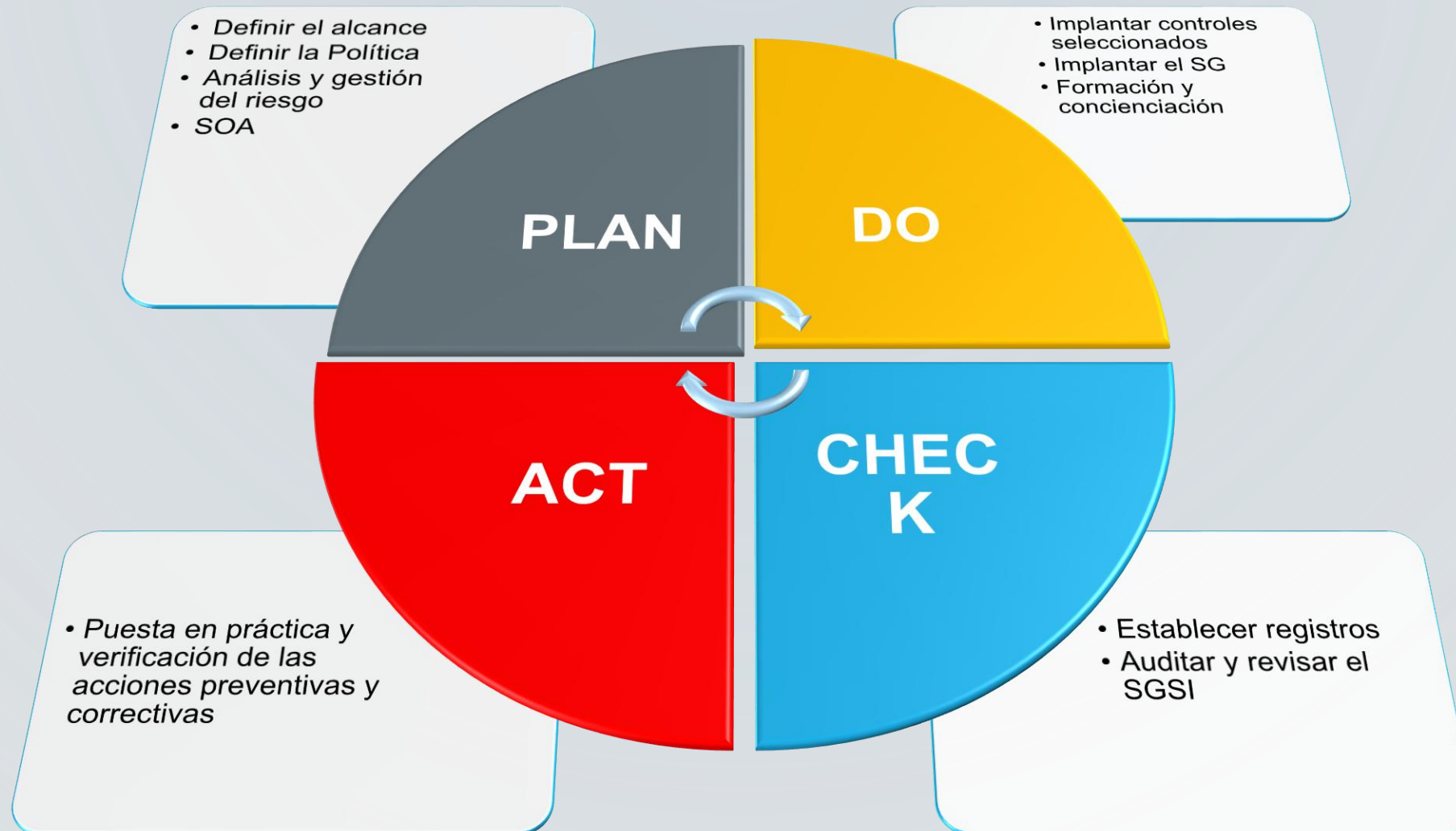
3.1 SGSI (BENEFICIOS)

- ❑ Establecimiento de una **metodología** de **gestión** de la seguridad estructurada
- ❑ **Reducción de riesgo** de pérdida, robo o corrupción de información
- ❑ las **auditorías externas ayudan cíclicamente** a identificar las debilidades del sistema y las áreas a mejorar
- ❑ Posibilidad de integrarse a otros sistemas (ISO 9001, ISO 14001, OHSAS 18001...)
- ❑ Conformidad con la legislación vigente sobre protección de datos personales, propiedad intelectual y otras
- ❑ Imagen de empresa a nivel internacional y elemento diferenciador de la competencia

4. METODOLOGÍA PDCA (ISO/IEC 27001)

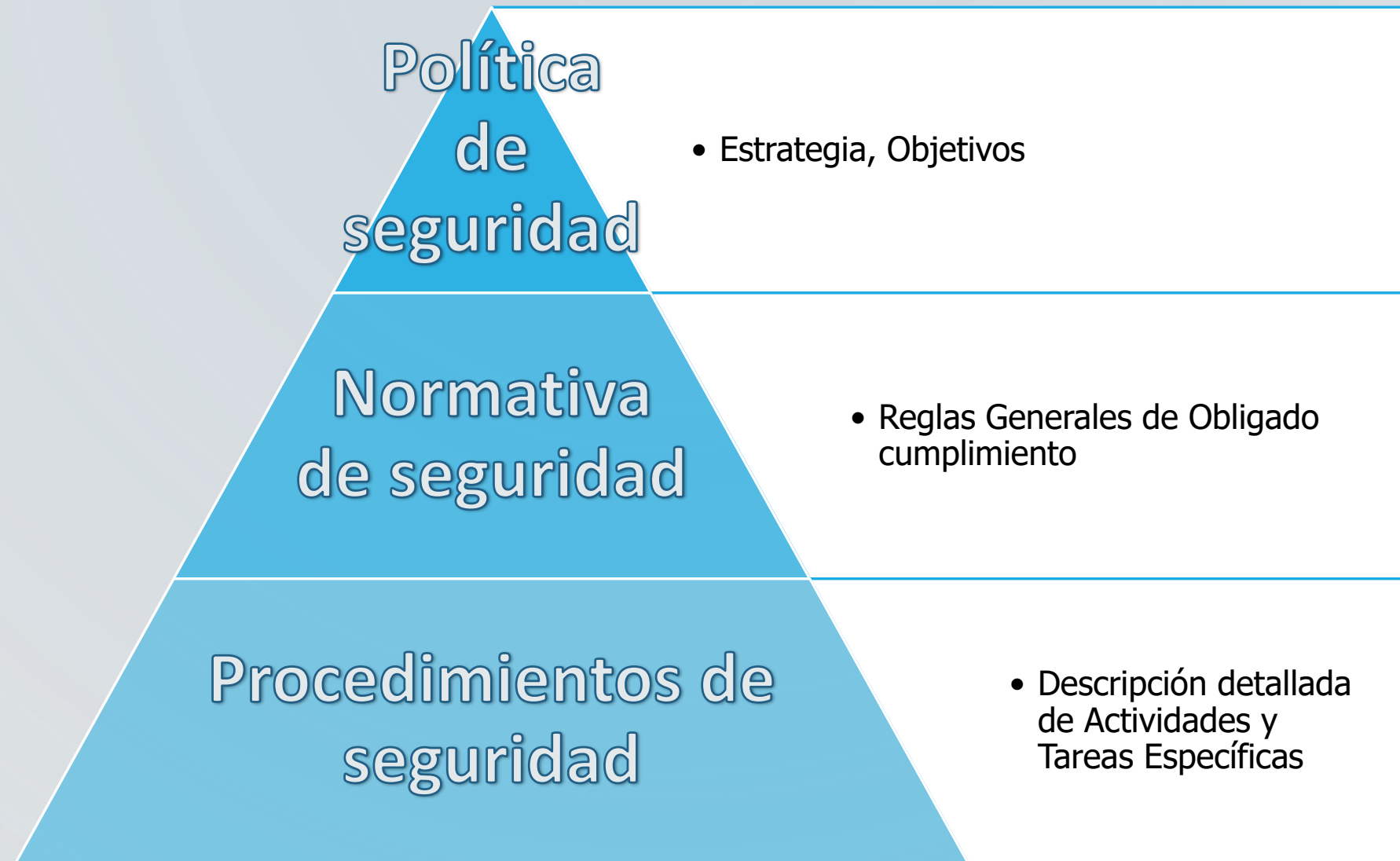


4. METODOLOGÍA PDCA (ISO/IEC 27001)



5. NIVELES SGSI

□ NIVELES



6. POLÍTICAS DE SEGURIDAD



6. POLÍTICA DE SEGURIDAD

- ❑ Una política de seguridad es una **declaración formal** de las normas impuestas por la empresa en cuestiones de seguridad de la información.
- ❑ Es un marco general y da una **orientación a alto nivel** de las directrices y principios de actuación al respecto de la seguridad de la información en la organización.
- ❑ Denota el **compromiso** de la **gerencia** con la seguridad de la información.
- ❑ Contiene los pilares exigibles en seguridad de la información del SGSI

6. POLÍTICA DE SEGURIDAD

❖ **OBJETIVO:** Dirigir y dar **soporte** a la **gestión de la seguridad de la información** en concordancia con los **requerimientos del negocio**, las leyes y las regulaciones.

□ La **gerencia** debería:

- Establecer una política de actuación
- Manifestar su **apoyo y compromiso** a la seguridad de la información

6. POLÍTICA DE SEGURIDAD

- La política tiene que **adaptarse a la empresa** y su actividad empresarial.
- **Requisitos legales**, reglamentarios y obligaciones contractuales relacionadas con la seguridad de la información.
- Marco para establecer todos los objetivos de seguridad de la información.
- **Alineada con la estrategia de riesgos.**
- Compromiso de la alta dirección y **aprobada formalmente** por ésta.
- **Comunicar** dentro de la organización y a todas **las partes interesadas.**
- **Debe ser revisada** de forma continua.

6.1 CONTENIDO DE UNA POLÍTICA DE SEGURIDAD

- La Política de Seguridad debiera contener enunciados relacionados con:
 - **Definición** de seguridad de la información, objetivos y alcance generales.
 - La **intención de la gerencia**, sus objetivos y principios de seguridad en línea con la estrategia de negocio.
 - Establecer los objetivos de control, los controles, y análisis y gestión de riesgos.
 - El **Alcance** del Sistema de Gestión de Seguridad de la Información.
 - **Responsabilidades** de las partes fundamentales del Sistema de Gestión de Seguridad de la Información.
 - Necesidad de **métricas** para impulsar la **mejora continua**.

7. NORMATIVA DE SEGURIDAD

•La normativa de Seguridad puede detallar reglas sobre:

1. Organización de la Seguridad de los SI.
2. Seguridad relativa a los recursos humanos.
3. Gestión de activos.
4. Control de acceso.
5. Criptografía.
6. Seguridad física y del entorno.
7. Gestión de operaciones.
8. Gestión de comunicaciones.
9. Adquisición, desarrollo y mantenimiento de SI.
10. Relación con proveedores.
11. Gestión de incidentes de SI.
12. Aspectos de SI para la gestión de la continuidad del negocio.
13. Cumplimientos legales.

7.1 RECURSOS HUMANOS

Antes del empleo

- Definir las funciones y responsabilidades de seguridad.
- Comprobación de los antecedentes.
- Los empleados deben firmar la aceptación de responsabilidades en lo relativo a Seguridad de la Información

Durante el empleo

- La dirección debe exigir que se aplique la seguridad de acuerdo a las políticas y procedimientos establecidos
- Los empleados deben recibir una adecuada concienciación y formación sobre políticas y procedimientos de la organización.
- Debe existir un proceso disciplinario formal para los empleados que incumplan la política de seguridad

Cese o cambio del empleo

- Las responsabilidades para proceder al cese o cambio deben estar claramente definidas.
- Los empleados deberán devolver todos los activos de la organización que estuvieran en su poder.
- Los derechos de acceso deben ser retirados a la finalización del empleo.

7.2 CUMPLIMIENTOS LEGALES

- **LEGISLACIÓN aplicable**

- ☐ El **cumplimiento** de la legislación hace que se esté **protegido** de posibles **amenazas** externas, aumenta el **respeto** de los derechos de **usuarios, clientes, proveedores** y además evita las **infracciones** involuntarias.
- ☐ Es **imprescindible explicar** y fundamentar, de forma clara y precisa, todos los **requerimientos normativos** y contractuales importantes correspondientes a cada sistema de información.

7.3 CUMPLIMIENTOS LEGALES

- **Resumen de algunas leyes españolas sobre las TIC**

- ☐ Ley Orgánica 3/2018, de 5 de diciembre, de **Protección de Datos Personales y garantía de los derechos digitales**
- ☐ Ley 34/2002 de Servicios de la Sociedad de la Información y de Comercio Electrónico (**LSSI**)
- ☐ Real Decreto Legislativo 1/1996 **Ley de Propiedad Intelectual**
- ☐ Ley 17/2001 de **Propiedad Industrial**
- ☐ Ley 39/2015, de 1 de octubre, del **Procedimiento Administrativo Común de las Administraciones Públicas**

8 SEGURIDAD ORGANIZATIVA

❑ No puede existir la seguridad sin organización, **se debe establecer una estructura de gestión** para iniciar y controlar la implantación del SGSI.

❑ Es necesario:

- Organizar **foros de gestión** con la gerencia
 - Identificar un **responsable** de **gestionar** la seguridad
 - Obtener la implicación de gerencia, establecer un **Comité de seguridad**
 - Tener en cuenta la seguridad **en las relaciones con terceros**

8 SEGURIDAD ORGANIZATIVA

- **OBJETIVO:** *Gestionar la seguridad de la información dentro de la organización.*
- Una buena organización debería tener en consideración lo siguiente:
 - Comité de gestión de SI
 - Coordinación SI multidisciplinar
 - **Asignación** clara de **responsabilidades**
 - **Autorización** de recursos
 - **Acuerdos** de **confidencialidad**
 - **Contacto** con las **autoridades**
 - **Contactos** con grupos de interés
 - **Revisión independiente** de la seguridad



8.1 ORGANIZACIÓN INTERNA

- **Comité de gestión de SI:**
 - Identificar **metas** de seguridad de la información
 - **Aprobar la política de seguridad** de información
 - **Revisar la efectividad** en la implementación de la política
 - Direcciones claras y apoyo en la gestión de la seguridad
 - **Proveer los recursos** necesarios
 - **Asignaciones de** roles específicos y **responsabilidades**
 - **Mantener la conciencia** en seguridad de información
 - **Asegurar** una **implementación** de los **controles** coordinada.

8.1 ORGANIZACIÓN INTERNA

❑ Coordinación SI multidisciplinar

- Las actividades de seguridad deben estar **coordinadas**
 - La seguridad de información debe implicar la cooperación y la **colaboración de todo el personal** de la entidad, así como requerir habilidades especiales.

❑ Asignación clara de **responsabilidades**

- Asignación de responsabilidades de acuerdo a la política de seguridad
- Identificación clara de las **responsabilidades** sobre **activos** individuales

8.1 ORGANIZACIÓN INTERNA

☐ **Autorización** de recursos

☐ **Acuerdos de confidencialidad**

- Establecer acuerdos de confidencialidad
- Tener en cuenta la legislación local (LOPDGDD)

☐ **Contacto** con las **autoridades**

☐ **Contacto** con **grupos de interés**

- Para mejorar conocimientos de seguridad
- **Recibir alertas** y estar informado de eventos
- **Intercambiar información** respecto a sistemas y sus vulnerabilidades

8.1 ORGANIZACIÓN INTERNA

- **Revisión independiente de seguridad**

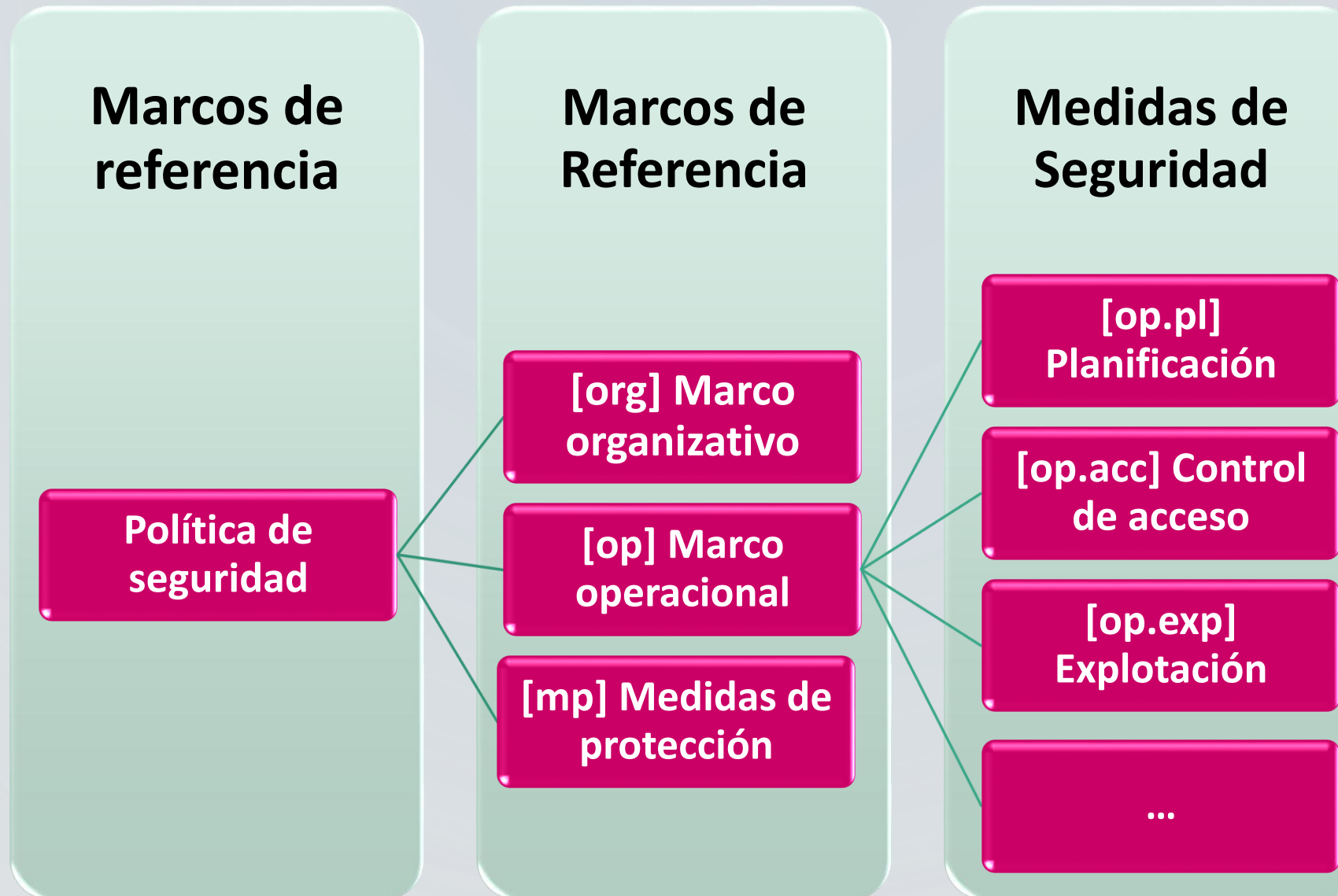
- Se debe asegurar un estado adecuado del sistema de forma periódica
- Se deben incluir oportunidades de **evaluación** y necesidades de **cambio**
- El personal que lleve a cabo la **revisión** debe ser **independiente** del área revisada, así como tener la experiencia apropiada y necesaria.



ESQUEMA NACIONAL DE SEGURIDAD (ENS)



1 CONTROLES PREVISTOS



2 POLÍTICAS DE SEGURIDAD (ENS)

❑ La política de seguridad será **aprobada por el órgano superior** competente que **corresponda**, de acuerdo con lo establecido en el [Artículo 11](#), y se plasmará en un documento escrito, en el que, de forma clara, se precise, al menos, lo siguiente:

- Los **objetivos** o **misión** de la organización.
- El marco **legal** y regulatorio en el que se desarrollarán las actividades.
- Los **roles** o funciones de seguridad, definiendo para cada uno, los deberes y responsabilidades del cargo, así como el procedimiento para su designación y renovación.
- La **estructura del comité** o los comités para la gestión y coordinación de la seguridad, detallando su ámbito de responsabilidad, los miembros y la relación con otros elementos de la organización.
- Las directrices para la estructuración de la documentación de seguridad del sistema, su gestión y acceso.

3 NORMATIVAS DE SEGURIDAD

❑ Se dispondrá de una serie de documentos que describan:

- **El uso correcto de equipos,** servicios e instalaciones.
- Lo que se considerará **uso indebido.**
- La responsabilidad del personal con respecto al cumplimiento o violación de estas normas: derechos, deberes y medidas disciplinarias de acuerdo con la legislación vigente.



4 PROCEDIMIENTOS DE SEGURIDAD

❑ Se dispondrá de una serie de documentos que detallen de forma clara y precisa:

- **CÓMO** llevar a cabo las tareas habituales.
- **QUIEN** debe hacer cada tarea.
- Cómo identificar y **REPORTAR** comportamientos **ANÓMALOS**.



ISA 99 – ISA/IEC 62443

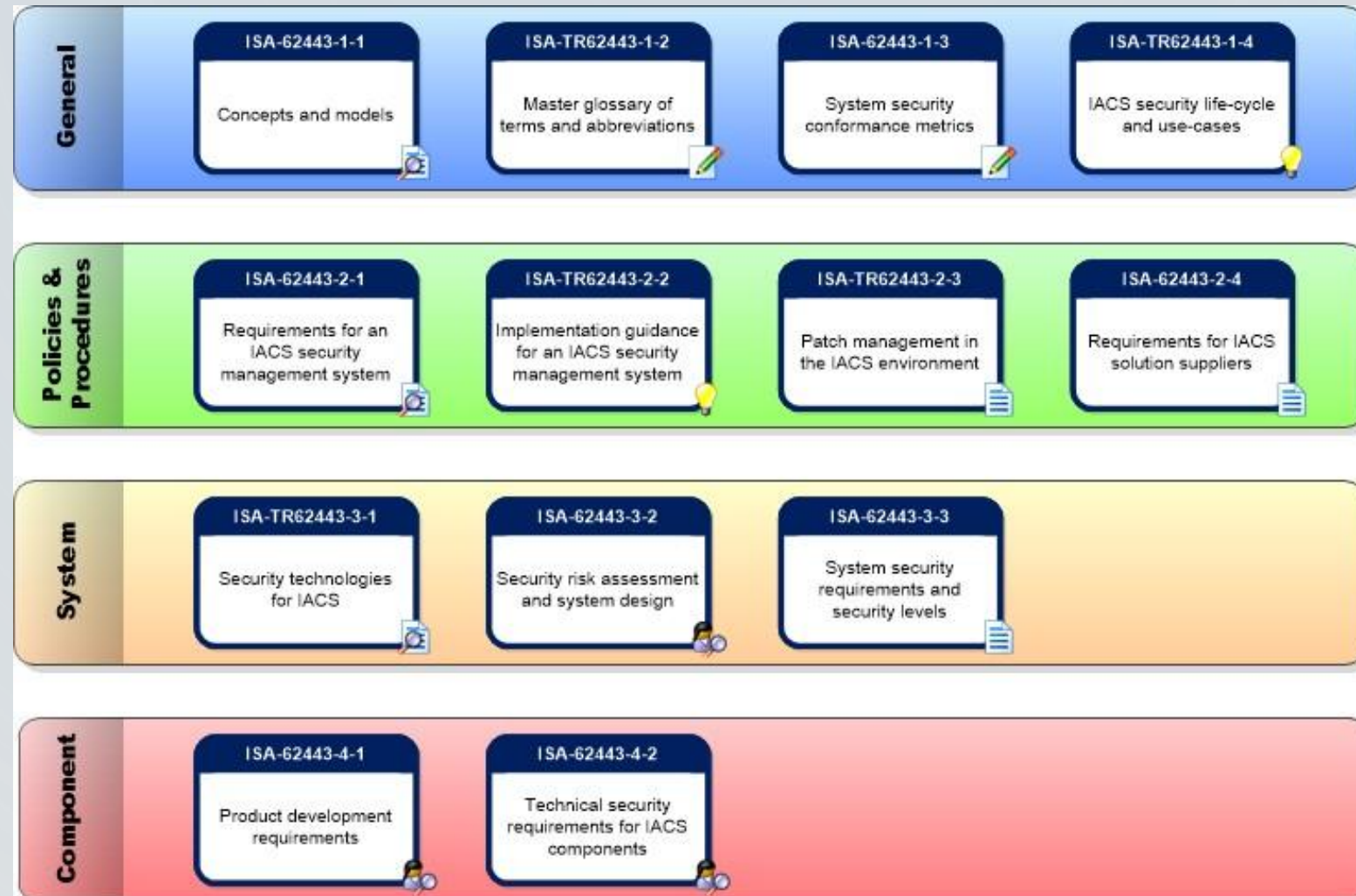


<https://www.isa.org/>

ESTÁNDARES DE SEGURIDAD



ESTÁNDARES DE SEGURIDAD



REGLAMENTO GENERAL DE PROTECCIÓN DE DATOS (RGPD)





LEY ORGÁNICA 3/2018, DE 5 DE DICIEMBRE, DE PROTECCIÓN DE DATOS PERSONALES Y GARANTÍA DE LOS DERECHOS DIGITALES



1 POLÍTICAS DE SEGURIDAD (RGPD)

☐ Política de privacidad de datos personales

- Se aplicará a **todos los sistemas y/o archivos que contengan datos personales** que sean objeto de tratamiento considerado como responsable y/o encargada del tratamiento de datos personales.
- Tiene la **finalidad** de asegurar el **respeto del derecho al honor y a la intimidad** en el tratamiento **de los datos de carácter personal** de todas las personas.
- Será de **aplicación en las empresas, a sus administradores, directivos y empleados**, así como a todas las personas que se relacionen con las sociedades pertenecientes a estos.

1 POLÍTICAS DE SEGURIDAD (RGPD)

❑ Principios del tratamiento de datos de carácter personal

- Principios relativos a la **recogida y al tratamiento** de los datos
- Principios en materia de **medidas de seguridad y confidencialidad**
- Principios sobre las **cesiones** de datos
- Principios sobre la contratación de encargados del tratamiento
- **Transferencias internacionales** de datos
- Principios sobre los **derechos** de los **afectados**

PREGUNTAS





GRACIAS POR SU ATENCIÓN